

API Security Risk Analysis Report

Prepared By:

Temesegeen Mekonnen

Future Interns – Cyber Security Internship

April 2026

Table of Contents

1. Introduction.....	2
2. Objectives	2
3. Tools Used.....	3
4. Scope and Methodology.....	3
5. API Analysis	3
5.1 /users Endpoint Analysis	3
5.2 /posts Endpoint Analysis	5
5.3 /comments Endpoint Analysis	6
6. Risk Summary.....	8
7. Recommendations.....	9
8. Conclusion	9

1. Introduction

Modern applications rely heavily on APIs for communication between services, mobile applications, and web platforms.

This report analyzes public API endpoints to identify common security risks such as excessive data exposure, missing authentication, and weak access controls.

2. Objectives

- Analyze public API endpoints
- Identify API security risks
- Assess authentication & authorization issues
- Detect excessive data exposure
- Provide remediation recommendations

3. Tools Used

- Postman
- Browser DevTools
- JSON Placeholder API
- Documentation & Analysis Tools: Microsoft 365

4. Scope and Methodology

This assessment focused on publicly accessible API endpoints provided by JSON Placeholder for educational and testing purposes.

The analysis was conducted using read-only requests through Postman and browser inspection tools. The assessment focused on identifying common API security risks including excessive data exposure, missing authentication controls, and unrestricted public access.

No exploitation, bypass attempts, or harmful testing activities were performed during this assessment.

5. API Analysis

5.1 /users Endpoint Analysis

Endpoint Tested: users

`https://jsonplaceholder.typicode.com/users`

Method: GET

Risk Level: Medium

Findings Identified

1. Open Public Endpoint

The endpoint is accessible without authentication or API tokens.

2. Excessive Data Exposure

The API exposes multiple user details including email addresses, phone numbers, and company information.

3. No Access Control

Any user can access all user records without restrictions.

4. Missing Rate Limiting Indicators

No visible protections against excessive automated requests were identified.

Business Impact:

Public exposure of user information may increase privacy and data leakage risks.

Remediation Suggestions:

- Require authentication for sensitive endpoints
- Limit exposed user data
- Implement access control policies

- Apply rate limiting protections

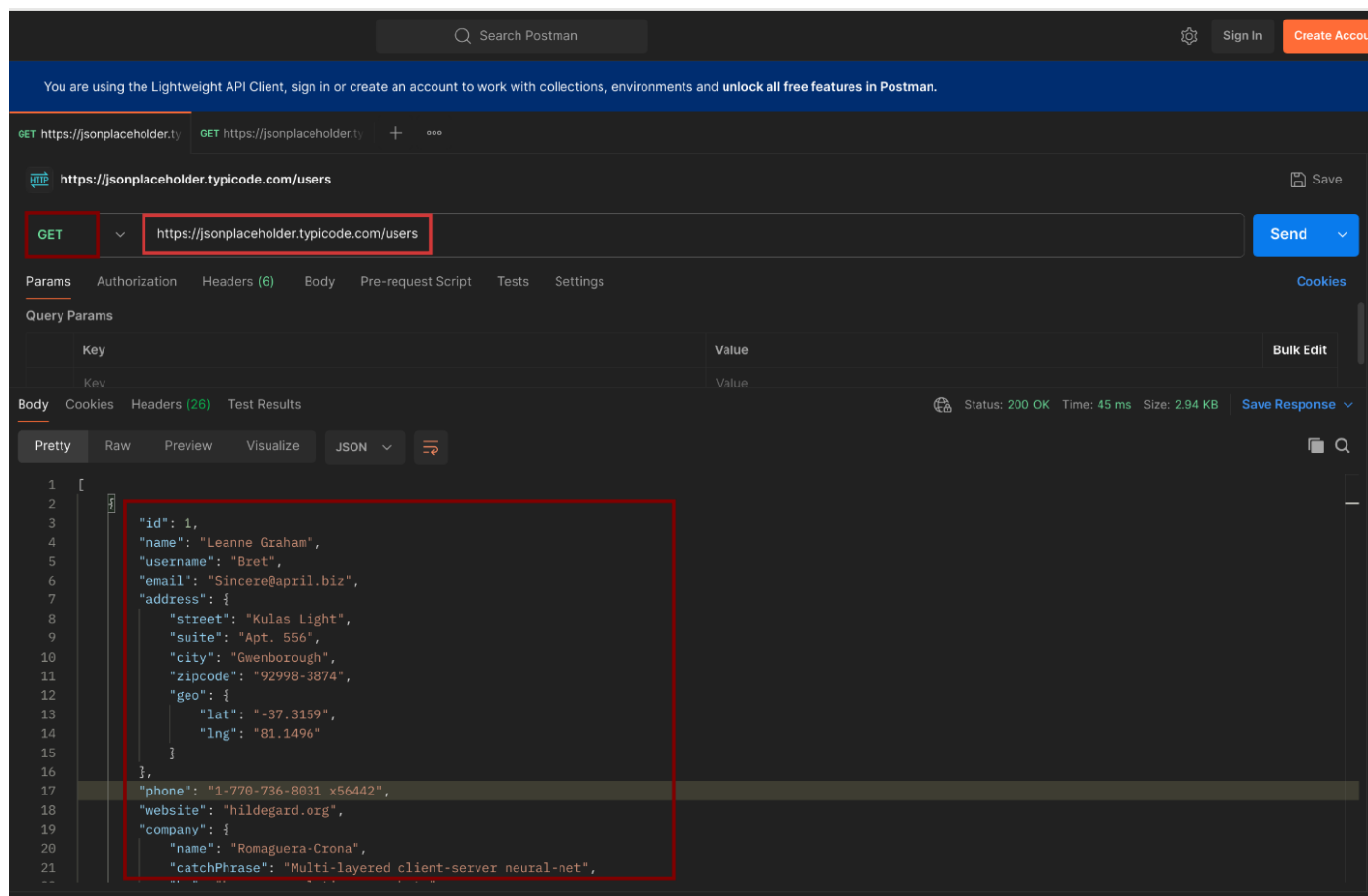


Figure 1: Postman Response for /users Endpoint

5.2 /posts Endpoint Analysis

Endpoint Tested: https://jsonplaceholder.typicode.com/posts

Method: GET

Risk Level: Low

Findings Identified:

1. Public Data Access

The endpoint allows unrestricted public access to post data.

2. No Authentication Required

Requests can be made without API keys or tokens.

3. Minimal Sensitive Information

The response does not expose critical personal information.

Business Impact:

Although low-risk, unrestricted access may still allow automated scraping or abuse.

Remediation Suggestions:

- Monitor API usage
- Apply optional authentication
- Use rate limiting for abuse prevention

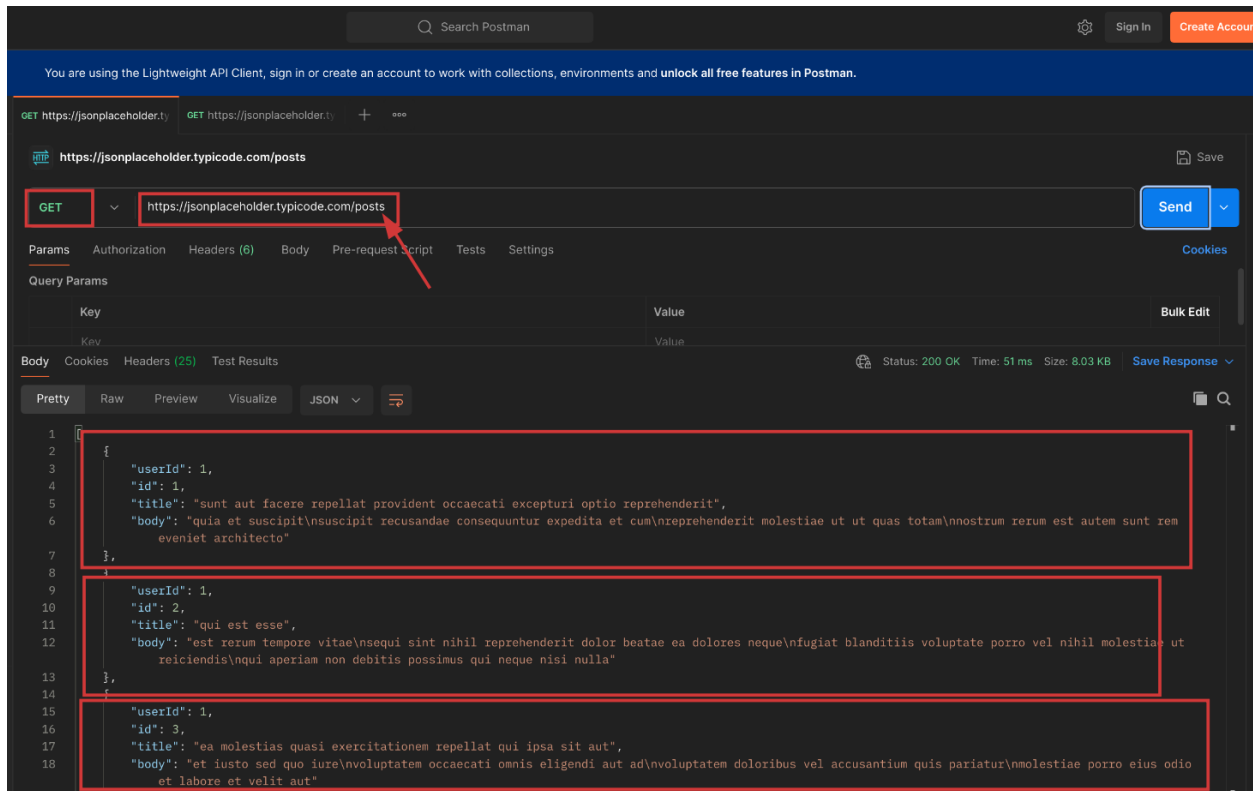


Figure 2: Postman Response for /posts Endpoint

5.3 /comments Endpoint Analysis

Endpoint Tested: <https://jsonplaceholder.typicode.com/comments>

Method: GET

Risk Level: Medium

Findings Identified:

1. Unauthenticated Access

The endpoint can be accessed publicly without verification.

2. Email Exposure

User email addresses are visible in API responses.

3. Potential Enumeration Risk

Large amounts of comment data can be collected automatically.

4. Missing Visible Request Restrictions

No visible request throttling protections were identified.

Business Impact:

Exposed email information may contribute to spam, phishing, or data harvesting risks.

Remediation Suggestions:

- Reduce exposed personal information
- Implement authentication where appropriate
- Apply rate limiting controls
- Restrict unnecessary data exposure

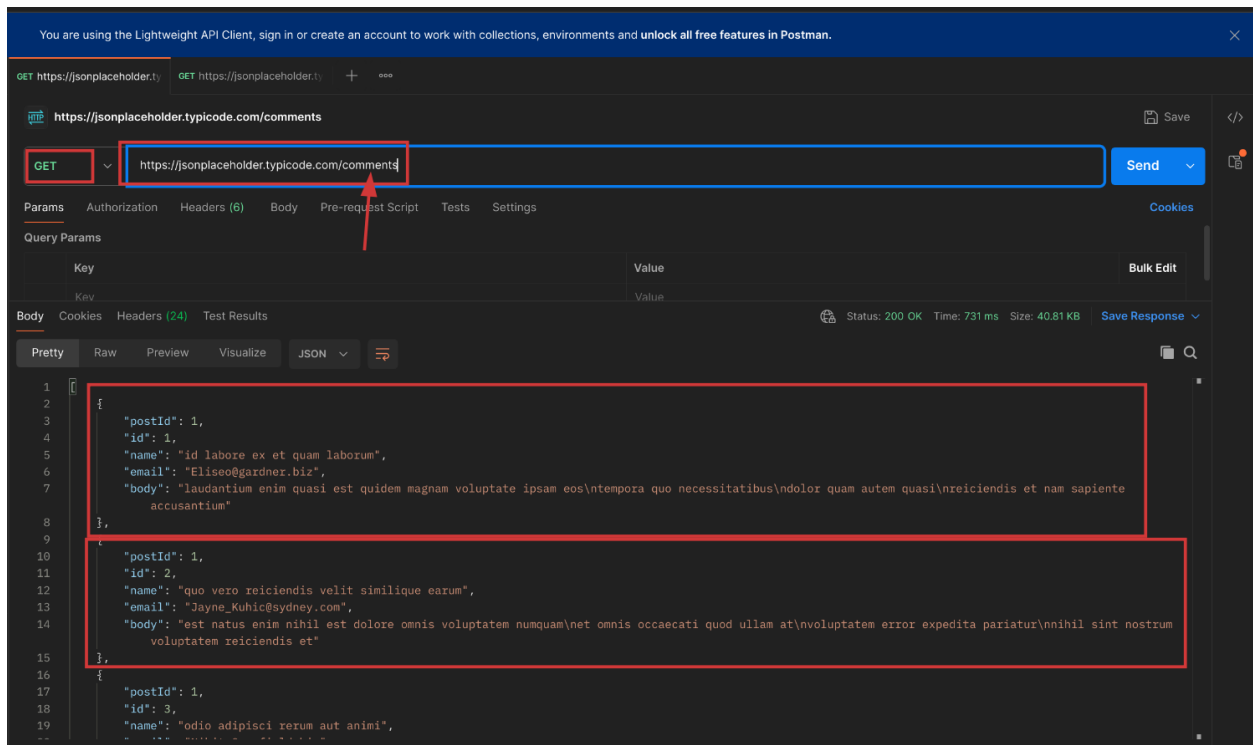


Figure 3: Postman Response for /comments Endpoint

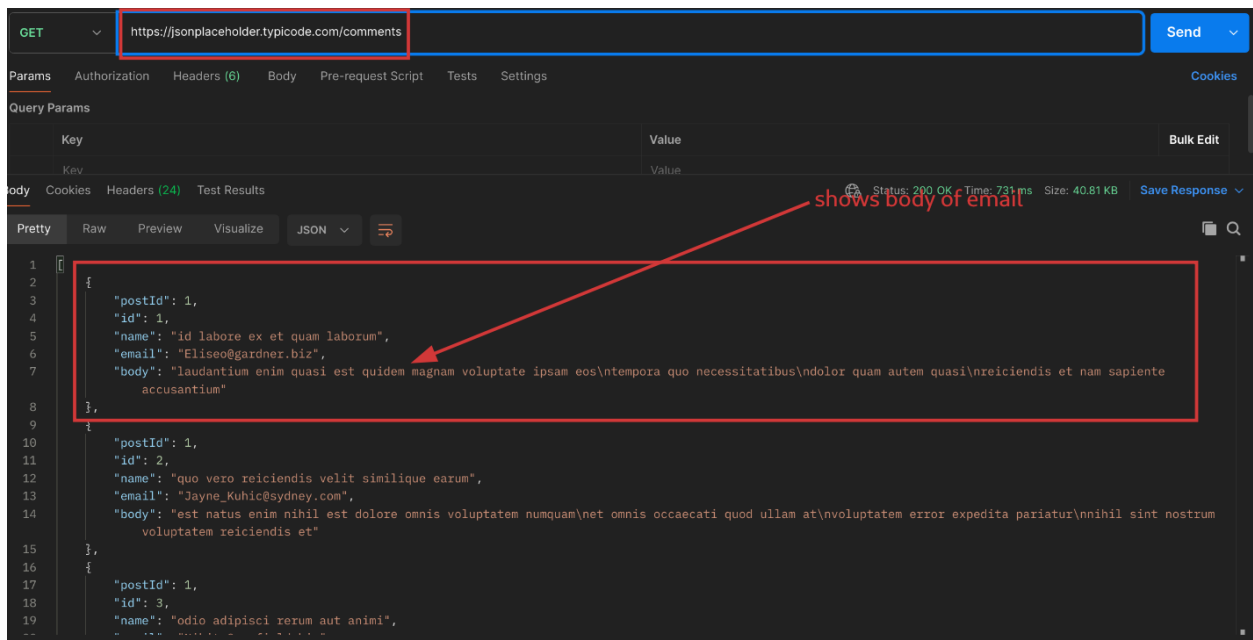


Figure 4: Example of Data Exposure in API Response

6. Risk Summary

Endpoint	Risk Level	Primary Risk
/users	Medium	Excessive Data Exposure
/posts	Low	Public Access
/comments	Medium	Email Exposure

The analysis identified multiple publicly accessible endpoints that expose user-related information without authentication. While the tested API is intentionally designed for learning purposes, similar configurations in production environments could increase privacy and security risks.

7. Recommendations

Based on the findings, the following security improvements are recommended:

- Implement authentication and authorization controls for sensitive endpoints.
- Limit the amount of user information returned in API responses.
- Apply rate limiting to reduce automated abuse and enumeration attempts.
- Implement role-based access control (RBAC) where appropriate.
- Regularly review API responses for unnecessary data exposure.
- Monitor API traffic and log suspicious activity.

8. Conclusion

This API Security Risk Analysis assessed several public API endpoints using safe, read-only testing techniques.

The assessment identified risks related to excessive data exposure, unauthenticated access, and the absence of visible request restrictions. While the analyzed API is intentionally public for learning purposes, similar issues in production environments could expose organizations to privacy, security, and compliance risks.

Implementing authentication controls, reducing exposed data, and enforcing rate limiting would significantly improve API security posture.